SECAI+ LESSON 6.3.1

Common Themes in AI Regulation

A practical framework for navigating regulatory expectations from governance and risk to transparency and third-party oversight.

The 8 Common Themes

01

Accountable Governance

02

Inventory & Risk Classification

03

Impact Assessments

04

Lawful Data Use & Human Oversight

05

Continuous Model Monitoring

06

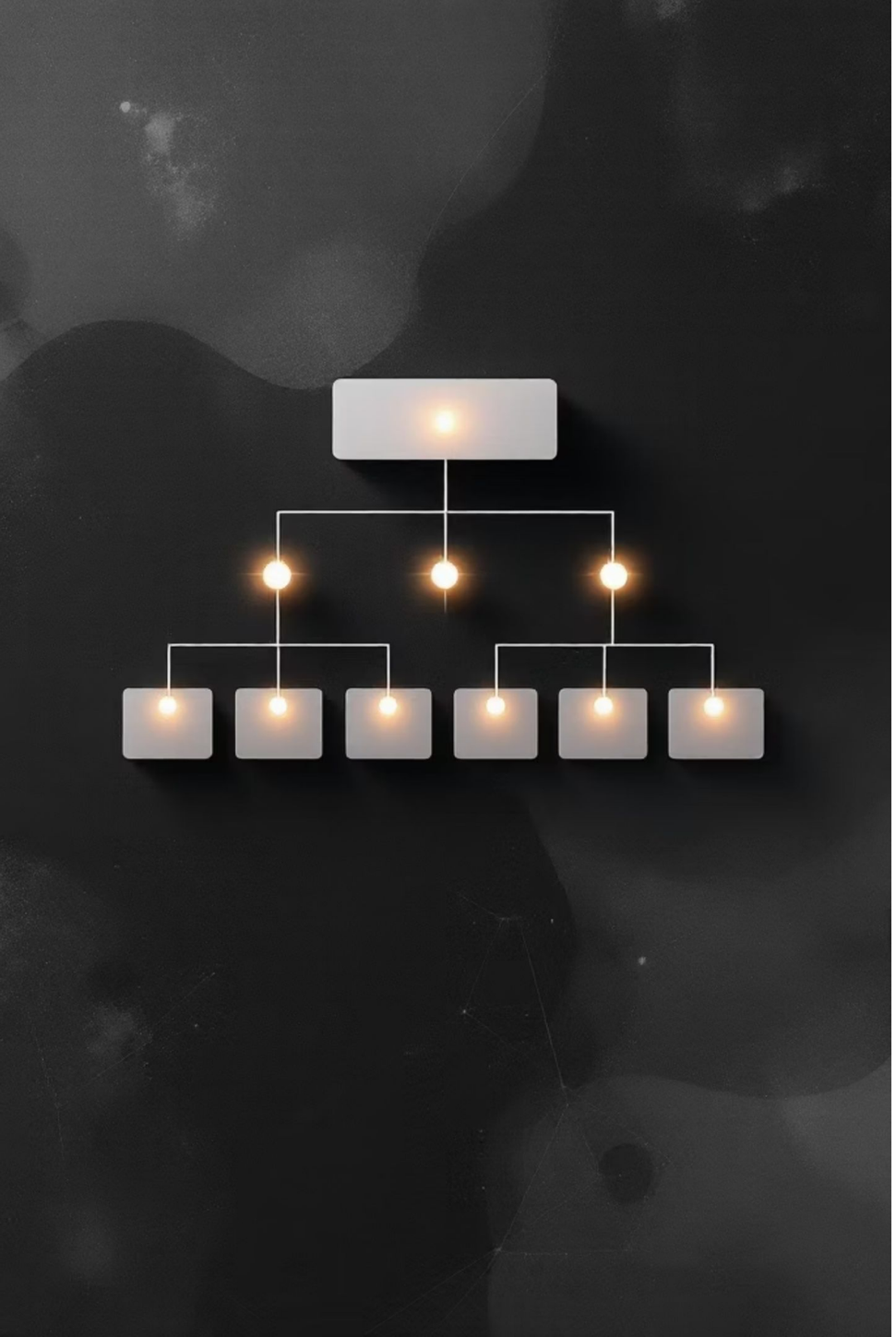
Accurate Claims

07

Third-Party Management

08

Transparency & User Rights



Establish Accountable Governance

What's Required

- Clearly define AI risk ownership
- Senior leadership oversight
- Documented decision records
- Internal policies tied to recognized frameworks

Why It Matters

Auditors must be able to trace requirements back to controls. A clear accountability chain prevents gaps and demonstrates regulatory readiness.

Inventory AI Use Cases & Classify Risk

AI Model Register

Maintain an up-to-date inventory of all AI models and tools in use.

Data Dependencies

Document intended use and the data each model relies on.

Risk Classification

Flag whether applications impact safety, rights, or protected classes.

Conduct Impact & Risk Assessments

Required before launching high-risk applications. Assessments must cover:

- 🔒 Data Protection
- ⚙️ Model Risk
- 🛡️ Security Threats
- ⚖️ Fairness & Accessibility
- 👤 Human Factors

Document testing methods, metrics, and acceptance criteria for every high-risk deployment.

Design for Lawful Data Use & Human Oversight

Data Principles

→ Data minimization

Collect only what's necessary.

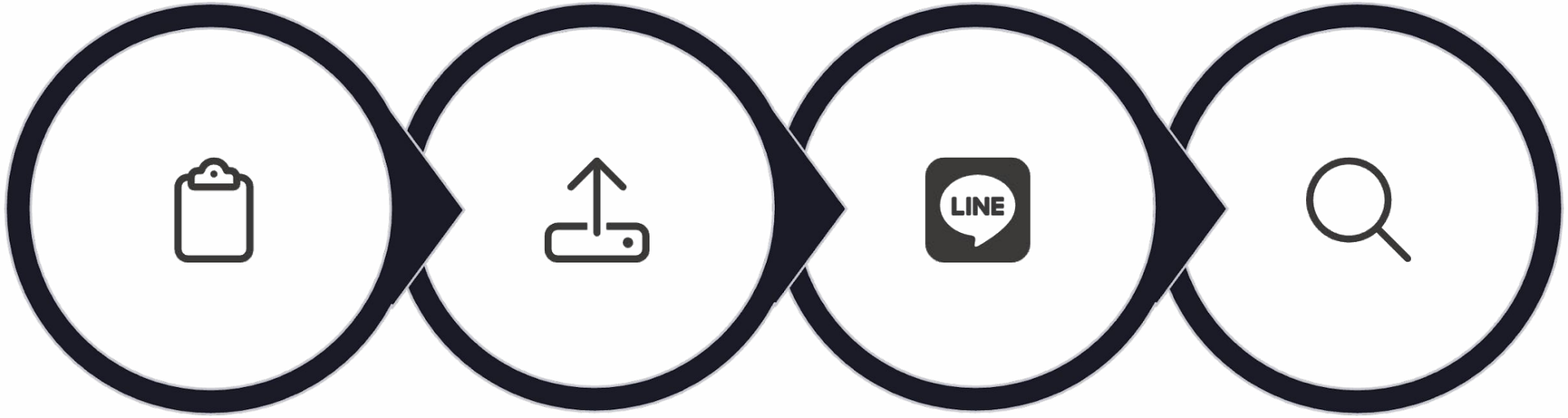
→ Purpose limitation

Use data only as intended and lawfully justified.

Human Oversight

- Meaningful human review for high-impact AI decisions
- Clear channels to contest automated outcomes
- Oversight scales with risk level

Measure & Manage Model Behavior Continuously



Define Protocols

Deploy Baselines

Monitor Drift

Investigate & Respond

Retain logs to investigate incidents and demonstrate post-market vigilance. Monitor for changes that could adversely affect protected classes or safety.

Ensure Claims Match Reality

Exaggerated or unsubstantiated AI claims can be treated as **deceptive by consumer protection regulators.**

Marketing materials

Must reflect verified results.

Documentation & UI

Align with actual model capabilities.

All disclosures

Must be accurate and substantiated.

Manage Third-Party & Open-Source Dependencies

Treat all external providers as **regulated suppliers** not just vendors.

Model Providers

Require documentation and security attestations.

Data Brokers & Annotators

Evidence of bias testing and data handling practices.

Toolmakers

Commitments to update and maintain offerings.

Key Takeaways

1. **Governance first**

   Assign clear AI risk ownership with senior oversight and auditable records.

2. **Know your AI inventory**

   Register every model, its data, and its risk classification before regulators ask.

3. **Assess before you launch**

   High-risk applications require documented impact assessments covering data, fairness, and security.

4. **Monitor continuously**

   Testing doesn't end at deployment — detect drift, retain logs, and demonstrate vigilance.

5. **Honesty is compliance**

   Accurate claims, transparent notices, and user recourse aren't optional, they're regulatory requirements.